

DOCUMENTO DE AUDITORIA FIAR

Repositorio base: FIAR-Audit-Template

Gerado automaticamente a partir dos artefatos preenchidos.

Data de geracao: 2026-05-29

Observacao: este PDF consolida evidencias; nao preenche conteudo automaticamente.

DATA CARD

Documentação de Dataset · FIAR / CIIA UFMG

Nome do Dataset:

NOME

0 · IDENTIFICAÇÃO DO DATASET

Nome	Nome completo do dataset e acrônimo, se houver.
Descrição	Resumo em até 200 palavras: o que são os dados, de onde vêm, para que servem.
Link / Repositório	URL do repositório ou sistema onde o dataset está armazenado.
Disponibilidade	Selecione um: Público / Restrito (acesso controlado) / Não público (interno)
Autores do Data Card	· Nome, Time, Papel (Proprietário / Contribuidor / Gestor) · Nome, Time, Papel (Proprietário / Contribuidor / Gestor) · Nome, Time, Papel (Proprietário / Contribuidor / Gestor)
Data de criação	MM/AAAA
Versão atual	Ex.: 1.0

1 · AUTORIA E RESPONSABILIDADE

1.1 Proprietários do Dataset

OBRIGATÓRIO

Equipe / Laboratório	Nome do grupo responsável pela curadoria técnica dos dados
Contato da equipe	E-mail ou mailing list do time
Autores individuais	· Nome, Título, Afiliação, Ano · Nome, Título, Afiliação, Ano · Nome, Título, Afiliação, Ano

1.2 Publicadores

OBRIGATÓRIO

Organização	Ex.: CIIA – Centro de Inteligência Artificial Aplicada, UFMG
Tipo	Selecione um: Acadêmico · Corporativo · Sem fins lucrativos · Outro (especifique)
Contato	Nome, e-mail, cargo

Website	URL (se disponível)
---------	---------------------

1.3 Financiadores

OPCIONAL

Instituição(ões)	Ex.: FAPEMIG, CNPq, MS, Empresa parceira
Programa / Edital	Nome do programa ou número do edital
Resumo do financiamento	Descreva brevemente o escopo do apoio financeiro. Inclua link se disponível.

2 · VISÃO GERAL DO DATASET

2.1 Características Gerais

OBRIGATÓRIO

Tipo de dado	Tabular · Imagem · Texto · Séries temporais · Multimodal · Outro (Especifique)
Formato dos arquivos	Ex.: CSV, Parquet, DICOM, HL7 FHIR, JSON
Tamanho total	Ex.: 4,2 GB
Nº de instâncias	Total de registros/linhas
Nº de campos/colunas	Total de atributos por instância
Período coberto	MM/AAAA – MM/AAAA · Desconhecido
Abrangência geográfica	Ex.: Belo Horizonte · MG · Nacional · Hospital X · Desconhecido

2.2 Descrição do Conteúdo

OBRIGATÓRIO

Descrição de uma Instância	Ex.: Cada linha representa um atendimento de paciente no SUS, identificado por CNS anonimizado.
Descrição dos Atributos	Insira aqui um resumo dos atributos, ou um link para um documento mais detalhado.

3 · SENSIBILIDADE E PRIVACIDADE

⚠ Dados de saúde são dados sensíveis nos termos da LGPD (Art. 11). Preencha esta seção com atenção redobrada.

3.1 Classificação dos Dados

OBRIGATÓRIO

Origem dos dados	Marque todos que se aplicam: Dados SUS (DATASUS, SIH, SIA, SINAN, SIVEP...) Dados de convênios / operadoras de saúde Dados de prontuário eletrônico (PEP) Dados de dispositivos / wearables Dados de entrevistas ou enquetes Dados gerados sinteticamente
------------------	---

	Outro (especifique)
Contém dados pessoais?	Selecione um: Sim, identificados · Sim, pseudonimizados · Sim, anonimizados · Não contém
Tipos de S/PII presentes	Ex.: CPF, CNS, Nome, Data de nascimento, CID-10, procedimento, endereço
Dados de crianças (<18)?	Selecione um: Sim · Não · Desconhecido

3.2 Campos com Dados Sensíveis

OBRIGATÓRIO

Liste abaixo todos os campos que contêm dados pessoais ou sensíveis:

Campo	Tipo de dado sensível	Coletado intencionalmente?	Medida de proteção aplicada

3.3 Base Legal e Conformidade

OBRIGATÓRIO

Base legal (LGPD)	Ex.: Tutela da saúde (Art. 7, VIII) · Pesquisa (Art. 7, IV) · Consentimento (Art. 7, I) · Outro
Parecer / CAAE	Número do parecer do CEP ou CAAE do projeto no CONEP/Plataforma Brasil
TCLE / Dispensa	Há Termo de Consentimento Livre e Esclarecido? Há dispensa aprovada pelo CEP?
Acordo de compartilhamento	Existe DPA (Data Processing Agreement) ou convênio formal com a fonte dos dados?
Medidas de segurança	Ex.: Anonimização k-anonimato, criptografia AES-256, acesso por VPN, ambiente de dados fechado

3.4 Riscos e Mitigações

OBRIGATÓRIO

Tipo(s) de risco	Marque todos que se aplicam: Risco Direto (reidentificação direta) Risco Indireto (cruzamento com outros datasets) Risco Residual (mesmo após anonimização) Nenhum risco conhecido
Descrição dos riscos	Descreva cada risco identificado e as mitigações adotadas.
Links de documentação	POP de segurança, DPIA, política de acesso...

4 · PROVENIÊNCIA E PROCESSAMENTO

4.1 Fontes Originais

OBRIGATÓRIO

Fonte(s)	Ex.: DATASUS · SIH-SUS · PEP do Hospital X · Sistema de convênio Y · Coleta primária prospectiva
Método de coleta	Ex.: Extração SQL · API REST · Raspagem web · Formulário físico digitalizado · Importação FHIR
Cadência de coleta	Selecione uma: Estática (coleta única) · Dinâmica (fluxo contínuo) · Atualização periódica (frequência: ____)
Linha do tempo	Período de coleta: MMM/AAAA – MMM/AAAA
Essa fonte é sensível?	Sim (justifique) · Não

4.2 Critérios de Inclusão e Exclusão

OBRIGATÓRIO

Critérios de inclusão	Ex.: Pacientes maiores de 18 anos, atendidos entre 2018–2023, com diagnóstico CID-10 J18 (pneumonia).
Critérios de exclusão	Ex.: Registros com mais de 30% de campos nulos; pacientes sem CNS válido.

4.3 Processamento dos Dados

OBRIGATÓRIO

Resumo do processamento	Escreva brevemente como foi feito o processamento de dados.
Ferramentas usadas	Ex: Nenhuma (processo manual), Scripts em Python (ou outra linguagem), SQL, aplicações de terceiros.
Integração de fontes	(Se há mais de uma fonte): como foram unificadas? Qual chave de ligação foi usada?
Documento descritivo	(Opcional): Link para documento mais detalhado sobre o processo

5 · MOTIVAÇÕES E INTENÇÕES DE USO

5.1 Motivações

OBRIGATÓRIO

Por que este dataset foi criado?	Descreva o problema de saúde ou questão de pesquisa que motivou a coleta.
Domínio de aplicação	Ex.: Epidemiologia · Diagnóstico assistido por IA · Gestão hospitalar · Farmacovigilância
Objetivo do projeto FIAR	Cite o projeto FIAR/CIIA ao qual este dataset está vinculado e os objetivos desse projeto.

5.2 Usos Pretendidos e Restrições

OBRIGATÓRIO

Casos de uso ADEQUADOS	Ex.: Treinamento de modelo de predição de reinternação; análise epidemiológica de doenças respiratórias.
------------------------	--

Casos de uso INADEQUADOS	<i>Ex.: Uso para fins comerciais sem autorização; tomada de decisão clínica automatizada sem supervisão médica; compartilhamento público irrestrito.</i>
Condições de uso	<i>Selecione um: Livre · Restrito a pesquisadores FIAR · Apenas com aprovação do CEP · Outro: ____</i>
Diretrizes de citação	<i>Como citar este dataset em publicações? Forneça formato BibTeX ou ABNT.</i>

6 · ATRIBUTOS HUMANOS E SENSÍVEIS

6.1 Atributos Representados

OBRIGATÓRIO

Atributos presentes	<i>Marque todos que se aplicam: Gênero / Sexo biológico Raça / Cor (autodeclarada) Idade / Faixa etária Condição socioeconômica Município / UF de residência Diagnóstico (CID/CIAP) Condição crônica / Comorbidade Plano de saúde / convênio Outro (especifique)</i>
Justificativa de inclusão	<i>Por que esses atributos são necessários para os objetivos do projeto?</i>
Método de coleta	<i>Autodeclarado · Inferido algoritmicamente · Extraído de registro oficial · Misto</i>

6.2 Riscos de Viés e Mitigações

OBRIGATÓRIO

Riscos de viés identificados	<i>Ex.: Sub-representação de populações rurais; viés de cobertura do SUS vs. dados de convênios.</i>
Correlações conhecidas	<i>Existem correlações entre atributos sensíveis que podem introduzir viés? Descreva.</i>
Mitigações adotadas	<i>Ex.: Balanceamento por faixa etária; análise de distribuição por raça/cor; teste de equidade de modelo.</i>

7 · MANUTENÇÃO E VERSÃO

7.1 Status e Versão Atual

OBRIGATÓRIO

Status de manutenção	<i>Selecione um: Constantemente atualizado · Ativamente em manutenção · Manutenção limitada · Descontinuado</i>
Versão atual	<i>Ex.: 1.0</i>
Data de lançamento	<i>MM/AAAA</i>
Última atualização	<i>MM/AAAA</i>
Plano de manutenção	<i>Descreva critérios de versionamento, processo para erros e canal de feedback.</i>

7.2 Próxima Atualização Planejada

OPCIONAL

Próxima versão	Ex.: 1.1
Data prevista	MM/AAAA
Mudanças esperadas	Descreva as atualizações de dados ou estrutura previstas.

8 · GLOSSÁRIO E TERMOS DE ARTE

Defina siglas, termos técnicos e conceitos utilizados ao longo do Data Card. Use definições padrão sempre que possível.

Termo / Sigla	Definição	Fonte / Referência

9 · REFLEXÕES SOBRE OS DADOS

Use este espaço para registrar observações que não se encaixam nas seções anteriores: limitações conhecidas, decisões éticas controversas, ou qualquer informação relevante para usuários futuros do dataset.

Observação 1	
Observação 2	
Observação 3	

MODEL CARD

Documentação de Modelo de IA · FIAR / CIIA UFMG

Nome do Modelo:

SEÇÃO 0

IDENTIFICAÇÃO DO MODELO

Nome do modelo	Nome completo e acrônimo. Ex.: Preditor de Risco de Reinternação Hospitalar (PRRH-v1)
Versão	Versão do modelo. Ex.: 1.0.0 — siga versionamento semântico (MAJOR.MINOR.PATCH)
Tipo / Arquitetura	Ex.: Classificador binário · Gradient Boosting (XGBoost) · Rede neural convolucional · LLM fine-tuned
Tarefa principal	Ex.: Classificação · Regressão · Detecção de objetos · Geração de texto · Segmentação de imagem
Desenvolvedor(es)	Nome, Time, Afiliação
Data de lançamento	Data de lançamento do modelo para operação. Formato: DD/MM/AAAA
Data de treinamento	Última data de treinamento do modelo. Formato: DD/MM/AAAA
Licença	Ex.: MIT · Apache 2.0 · CC BY 4.0 · Uso restrito FIAR · Proprietário
Link / Repositório	URL do repositório de código, modelo ou sistema de versionamento de experimentos (MLflow, W&B...)

SEÇÃO 1

CONTEXTO E USO PRETENDIDO

1.1 Descrição e Motivação

OBRIGATÓRIO

Descrição do modelo	Em até 200 palavras: o que o modelo faz, como funciona em linhas gerais e qual problema resolve.
Motivação	Por que este modelo foi desenvolvido? Qual a lacuna ou necessidade clínica/operacional que justifica sua criação?
Projeto CIIA	Cite o projeto CIIA ao qual este modelo está vinculado.

1.2 Usuários e Casos de Uso

OBRIGATÓRIO

Usuários esperados	<i>Quem vai utilizar ou interagir com este modelo? Ex.: Pesquisadores CIIA · Clínicos (com supervisão) · Gestores de saúde · Sistema automatizado de triagem</i>
Grupos Impactados pelo Modelo	<i>Indivíduos ou populações impactados diretamente ou indiretamente pelas decisões ou recomendações do modelo.</i>
Casos de uso adequados	<i>Descreva os cenários para os quais o modelo foi projetado e validado.</i>
Casos de uso INADEQUADOS	<i>Usos que parecem plausíveis, mas não são recomendados. Ex.: tomada de decisão clínica autônoma sem supervisão médica; uso em populações fora do escopo de treinamento; utilizo como dispositivo médico sem registro da ANVISA.</i>
Condições de implantação	<i>Ambiente esperado: hospitalar · pesquisa · produção restrita · piloto. Há pré-requisitos de infraestrutura ou integração (HIS, PACS, EHR)?</i>

⚠ Modelos de IA aplicados a decisões clínicas diretas podem ser classificados como dispositivos médicos pela ANVISA (RDC 657/2022). Verifique a necessidade de registro antes de implantar em ambiente assistencial.

SEÇÃO 2

DADOS DE TREINAMENTO E AVALIAÇÃO

2.1 Dados de Treinamento

OBRIGATÓRIO

Dataset(s) utilizados	<i>Nome e versão dos datasets. Referencie os Data Cards correspondentes.</i>
Tamanho do conjunto	<i>Nº de instâncias utilizadas para treino. Se houve divisão treino/validação/teste, informe as proporções.</i>
Período dos dados	<i>Janela temporal coberta pelos dados de treinamento. Relevante para detectar data drift.</i>
Pré-processamento	<i>Descreva as transformações aplicadas: normalização, imputação, encoding, balanceamento de classes (SMOTE, undersampling...)</i>
Privacidade e Proteção de Dados	<i>Práticas adotadas para proteção de dados sensíveis: remoção de identificadores, pseudonimização, controle de acesso. Obs: A avaliação detalhada de riscos e conformidade é realizada no Artefato de Privacidade do FIAR-Saúde.</i>
Limitações dos dados de treino	<i>Quais populações ou cenários estão sub-representados? Que vieses os dados de origem podem ter introduzido?</i>

2.2 Dados de Avaliação

OBRIGATÓRIO

Dataset(s) de avaliação	<i>Nome e versão. Indique se é holdout do mesmo dataset de treino ou conjunto externo independente.</i>
Tamanho do conjunto	<i>Nº de instâncias utilizadas para avaliação.</i>
Representatividade	<i>Os dados de avaliação representam a população-alvo de implantação? Há diferenças relevantes em relação ao treino (distribuição, período, origem)?</i>

SEÇÃO 3

ARQUITETURA E TREINAMENTO

3.1 Especificações Técnicas

OBRIGATÓRIO

Framework / biblioteca	Ex.: scikit-learn 1.3 · PyTorch 2.1 · TensorFlow 2.14 · Hugging Face Transformers 4.x
Hiperparâmetros principais	Liste os hiperparâmetros mais relevantes (taxa de aprendizado, profundidade, nº de estimadores...). Referencie arquivo de configuração se disponível.
Hardware de treinamento	Recursos computacionais utilizados no treinamento. Ex.: GPU NVIDIA A100 40GB · CPU 32 cores · Cluster FIAR
Ambiente de Treinamento	Localização física ou computacional do treinamento para fins de rastreabilidade e compliance. Inclui o tipo de infraestrutura (on-premise, cloud ou híbrida), o nível de isolamento do ambiente e as políticas de controle de acesso adotadas.
Tempo de treinamento	Tempo aproximado de um ciclo de treinamento completo.
Estratégia de validação	Ex.: Cross-validation k=5 estratificado · Holdout 80/10/10 · Validação temporal (train em 2018–2021, test em 2022–2023)

3.2 Fatores de Influência no Desempenho

OBRIGATÓRIO

Fatores externos ao modelo que podem afetar seu desempenho em produção:

Fatores de grupo	Ex.: desempenho pode variar por faixa etária, sexo, raça/cor, região geográfica, tipo de hospital (porte, público/privado)
Fatores instrumentais	Ex.: qualidade de preenchimento do prontuário, versão do equipamento de imagem, sistema de saúde (SUS vs. convênio)
Fatores ambientais	Ex.: sazonalidade de doenças, eventos pandêmicos, mudanças de protocolos clínicos, ICD-10 vs. ICD-11
Data drift esperado	Com que velocidade os dados de entrada podem mudar a ponto de degradar o modelo? Com que frequência deve ser reavaliado?

SEÇÃO 4

AVALIAÇÃO DE DESEMPENHO

4.1 Métricas Utilizadas

OBRIGATÓRIO

Métricas primárias	Ex.: AUROC · F1-score · Sensibilidade · Especificidade · RMSE. Justifique a escolha no contexto clínico.
Métricas secundárias	Ex.: Calibração (Brier Score, curva de calibração) · Tempo de inferência · Uso de memória
Limiar de decisão	Se classificador binário: qual threshold foi escolhido e com qual critério? (ex.: maximizar sensibilidade para não perder casos graves)

4.2 Resultados Gerais

OBRIGATÓRIO

Preencha a tabela com os resultados no conjunto de avaliação:

Métrica	Descrição	Resultado	Intervalo de Confiança (95%)

4.3 Desempenho por Subgrupo

OBRIGATÓRIO

⚠ CAMPO CRÍTICO para IA Responsável — avalie o modelo separadamente para grupos populacionais relevantes.

Subgrupos prioritários em saúde: faixa etária · sexo · raça/cor · região geográfica · tipo de cobertura (SUS / convênio) · porte do hospital.

Subgrupo	Categoria	Métrica Principal	Resultado	Δ vs. Geral

4.4 Análise de Erros

OBRIGATÓRIO

Falsos positivos	Qual é o impacto clínico/operacional de um falso positivo? Ex.: exame desnecessário, ansiedade do paciente, custo.
Falsos negativos	Qual é o impacto de um falso negativo? Ex.: diagnóstico perdido, tratamento tardio, risco à vida.
Padrões de erro observados	O modelo erra mais em algum subgrupo ou tipo de caso? Documente padrões identificados na análise de erros.

SEÇÃO 5

CONSIDERAÇÕES ÉTICAS E DE EQUIDADE

5.1 Impactos Éticos

OBRIGATÓRIO

Impactos positivos esperados	Ex.: detecção precoce de sepse · redução de internações evitáveis · apoio à triagem em regiões com escassez de especialistas
Impactos negativos potenciais	Ex.: automação de decisões que deveriam ter supervisão humana · amplificação de desigualdades existentes nos dados · redução da autonomia do paciente

Populações em risco	<i>Quais grupos são mais vulneráveis a danos causados por erros do modelo? Como o modelo foi validado para eles?</i>
----------------------------	--

5.2 Avaliação de Viés e Equidade

OBRIGATÓRIO

Atributos sensíveis analisados	<i>Quais atributos (raça/cor, sexo, idade, cobertura de saúde...) foram investigados na análise de equidade?</i>
Métricas de equidade utilizadas	<i>Ex.: equalized odds gap · demographic parity · calibration by group. Referencie biblioteca utilizada (Fairlearn, AIF360...) inserir link "Para detalhes das fórmulas e bibliotecas (Fairlearn/AIF360), consulte o Artefato de Justiça".</i>
Resultados da análise de equidade	<i>Descreva apenas a conclusão principal, (ex: "O modelo apresenta paridade demográfica entre sexos, mas há um gap de 5% na sensibilidade para a faixa etária acima de 70 anos").</i>
Mitigações adotadas	<i>Ex.: re-balanceamento de classes, ajuste de threshold por grupo, remoção de atributos proxy, regularização de equidade. Caso haja, descrição breve sobre o que foi feito, mais detalhes, link para o Fairness report.</i>
Vieses residuais conhecidos	<i>Quais vieses não foram totalmente mitigados? Quais limitações o usuário deve conhecer antes de implantar?</i>

5.3 Conformidade Regulatória

OBRIGATÓRIO

Classificação de risco <i>CFM N° 2454</i>	<i>Baixo · Médio · Alto — baseado no impacto potencial e reversibilidade das decisões apoiadas pelo modelo</i>
Parecer ético / CAAE	<i>Número do CAAE ou parecer do CEP que cobre o desenvolvimento e uso deste modelo</i>
Avaliação de Impacto à Proteção de Dados(DPIA)	<i>Foi realizada uma Avaliação de Impacto à Proteção de Dados (LGPD Art. 38)? Referência do documento.</i>
Avaliação de Impacto Algorítmico (AIA)	<i>Foi realizada uma Avaliação de Impacto Algorítmico (CFM N° 2.454 Anexo I Inciso XIII)? Referência do documento.</i>
Conformidade EU AI Act	<i>Se aplicável: o modelo se enquadra em alguma categoria de alto risco do Anexo III? Quais obrigações se aplicam?</i>

SEÇÃO 7

EXPLICABILIDADE E INTERPRETABILIDADE

Tipo de Explicabilidade	<i>Classificação da abordagem utilizada (Ex: Global e Local).</i>
Método e Técnicas	<i>Técnicas utilizadas para tornar os resultados compreensíveis (ex.: SHAP, LIME ou Árvores de Decisão intrinsecamente interpretáveis).</i>
Apresentação ao Usuário	<i>Descreva como a explicação chega ao médico (ex: "O sistema destaca os termos do prontuário que mais contribuíram para o score de risco").</i>

[Link para Auditoria](#)

Análise completa de interpretabilidade disponível no Artefato de Explicabilidade

SEÇÃO 8

IMPLANTAÇÃO E OPERAÇÃO

♦ SEÇÃO NOVA — ausente no template original (Mitchell et al., 2018).

Essencial para projetos que saem de pesquisa para produção ou piloto clínico.

8.1 Requisitos Técnicos

OBRIGATÓRIO

Ambiente de execução	Ex.: Python 3.10+ · Docker · API REST · integração HL7 FHIR · plugin HIS
Dependências	Bibliotecas e versões necessárias. Referencie requirements.txt ou environment.yml.
Requisitos mínimos de hardware	Especificações necessárias de processamento (CPU/GPU), memória RAM e armazenamento. O modelo exige hardware dedicado para execução?
Tempo de inferência	Tempo médio por predição em produção. Há restrições de latência?
Integração esperada	Como o modelo se integra ao fluxo de trabalho existente? (Ex.: alerta no prontuário, dashboard, API consumida por outro sistema)

8.2 Monitoramento e Manutenção

OBRIGATÓRIO

Monitoramento de desempenho	Como o desempenho do modelo será monitorado em produção? Com que frequência? Quais alertas serão disparados?
Detecção de data drift	Qual metodologia será usada para detectar que os dados de entrada mudaram significativamente? (PSI, KL divergence, CUSUM...)
Critério de retreinamento	Em que condições o modelo deve ser retreinado? (degradação de métrica, drift detectado, mudança de protocolo clínico)
Responsável técnico	Quem é responsável pelo monitoramento e pelo gatilho de retreinamento em produção?

SEÇÃO 9

LIMITAÇÕES, AVISOS E RECOMENDAÇÕES

Capacidades conhecidas	O que o modelo executa com excelência? Quais são os cenários ideais e o seu escopo de maior confiabilidade?
Limitações conhecidas	O que o modelo não consegue fazer bem? Quais são os limites do seu escopo de validade?
Avisos críticos	Informações que o usuário DEVE saber antes de usar o modelo. Ex.: não validado em crianças; não usar em gestantes; desempenho não testado em hospitais de pequeno porte.

Recomendações de uso	Boas práticas para quem implantar ou usar o modelo. Ex.: sempre associar a supervisão clínica; revisar predições de baixa confiança; não usar como critério único de decisão.
Trabalhos futuros <i>opcional</i>	Que melhorias ou validações adicionais são recomendadas? O que está fora do escopo desta versão?

SEÇÃO 10

VERSIONAMENTO E HISTÓRICO DO CARD

◆ SEÇÃO NOVA — referência às melhores práticas atuais de MLOps.
Essencial para rastreabilidade: relaciona cada versão do modelo aos dados e código que a geraram.

Versão	Versão do Model Card. Ex.: 1.0.0
Descrição da atualização	Detalhamento do que foi alterado nesta versão e o porquê.
Data de modificação	Última data de modificação. Formato: DD/MM/AAAA
Código-fonte	Commit hash ou tag no repositório do código-fonte do Model Card.
Histórico de modificações	Registro cronológico das atualizações deste Model Card. Ex.: v1.0.0 (18/01/25): Deploy inicial e validação · v1.1.0 (05/04/25): Ajuste de pesos do modelo para mitigação de viés demográfico identificado em auditoria interna.

Adaptado de Mitchell et al. (2018) "Model Cards for Model Reporting" · ACM FAccT 2019 · Incorpora práticas de Hugging Face Model Card Guidebook, NVIDIA Model Card++, EU AI Act (2024) e CFM N° 2454.

RELATÓRIO DE IMPACTO À PROTEÇÃO DE DADOS PESSOAIS (RIPD)

FIAR / CIIA UFMG

Versão 1.0 - <Local>, <dia> de <mês> de <ano>

Data	Versão	Descrição	Autor
DD/MM/AAAA	1.0	Primeira versão do Relatório de Impacto à Proteção de Dados Pessoais (RIPD) no contexto do NIAR-Saúde.	XXXX

Objetivo

O Relatório de Impacto à Proteção de Dados Pessoais (RIPD) visa descrever os processos de tratamento de dados pessoais que podem gerar alto risco à garantia dos princípios gerais de proteção de dados pessoais previstos na Lei nº 13.709/18 (Lei Geral de Proteção de Dados Pessoais - LGPD) e às liberdades civis e aos direitos fundamentais, bem como medidas, salvaguardas e mecanismos de mitigação de risco.

Referência: Art. 5º, inciso XVII, da LGPD.

⚠ ATENÇÃO

Este RIPD é composto por notas e exemplos orientativos sobre o preenchimento do documento, bem como valores genéricos para os campos. Remova todas as notas, exemplos em itálico e valores genéricos do *template* FINAL.

SEÇÃO 1

IDENTIFICAÇÃO DOS AGENTES DE TRATAMENTO E DO ENCARREGADO

OBJETIVO DA SEÇÃO

Identificar os agentes de tratamento e o encarregado no escopo das operações do FIAR, de forma clara e imediata.

Controlador

Nome: XXXX

Nome da pessoa natural ou jurídica, de direito público ou privado, a quem competem as decisões referentes ao tratamento de dados pessoais.

Operador

Nome: XXXX

Nome da pessoa natural ou jurídica, de direito público ou privado, que realiza o tratamento de dados pessoais em nome do controlador.

Encarregado

Nome: XXXX

Nome da pessoa indicada pelo controlador e operador para atuar como canal de comunicação entre o controlador, os titulares dos dados e a Autoridade Nacional de Proteção de Dados – ANPD.

Endereço de e-mail: XXXX

xxxx.xxxx.gov.br

Número de telefone: XXXX

(99) 9999-9999

SEÇÃO 2

NECESSIDADE DE ELABORAR O RELATÓRIO

OBJETIVO DA SEÇÃO

Identificar o motivo para a elaboração do RIPD, considerando operações de tratamento de dados pessoais que possam gerar alto risco aos princípios gerais de proteção de dados pessoais previstos na LGPD e às liberdades civis e aos direitos fundamentais dos titulares.

NECESSIDADE PARA O RIPD

Necessidade: XXXX

NOTA

Exemplos de situações em que o RIPD poderá ser necessário:

- tecnologia, serviço ou outra iniciativa em que dados pessoais e dados pessoais sensíveis sejam ou devam ser tratados;
- rastreamento da localização dos indivíduos ou qualquer outra ação de tratamento que vise a formação de perfil comportamental de pessoa natural, se identificada;
- tratamento de dado pessoal sensível;
- processamento de dados pessoais para tomar decisões automatizadas que possam ter efeitos legais, incluídas as destinadas a definir perfil pessoal, profissional, de consumo e de crédito ou aspectos de personalidade;
- tratamento de dados pessoais de crianças e adolescentes;
- tratamento de dados que possa resultar em dano patrimonial, moral, individual ou coletivo aos titulares, se houver vazamento;
- tratamento com fundamento no interesse legítimo do controlador; e
- alterações nas leis e regulamentos aplicáveis à privacidade, política e normas internas, operação do sistema de informações, propósitos e meios para tratar dados, fluxos de dados novos ou alterados etc.

NOTA

Exemplos de situações em que o RIPD poderá ser exigido pela ANPD:

- tratamento pelo Poder Público; e
- tratamento comandado por controladores em geral, inclusive no caso de operações que envolvam dados pessoais sensíveis.

NOTA

O RIPD poderá ser implementado como parte de programa de governança em privacidade.

SEÇÃO 3

DESCRIÇÃO DO TRATAMENTO

OBJETIVO DA SEÇÃO

Especificar a **natureza**, o **escopo**, o **contexto** e a **finalidade** das operações de tratamento de dados pessoais, considerando o cenário institucional e fornecendo subsídios para avaliação e mitigação de riscos.

NATUREZA**Descrição do tratamento:** XXXX

Descrever, por exemplo:

- *como os dados são coletados, retidos/armazenados, tratados, usados e eliminados;*
- *fonte utilizada para a coleta dos dados pessoais (ex.: titular de dados, planilha eletrônica, arquivo xml, formulário em papel etc.);*
- *com quais órgãos, entidades ou empresas dados pessoais são compartilhados e quais são esses dados;*
- *quais são os operadores que realizam o tratamento de dados pessoais e em quais fases eles atuam (coleta, retenção, processamento, compartilhamento, eliminação);*
- *se alguma nova tecnologia ou método de tratamento foi adotado recentemente que envolva dados pessoais; e*
- *medidas de segurança atualmente adotadas.*

NOTA

Pode ser importante consultar documentação que demonstre os fluxos de dados (ex: diagrama).

NOTA

Exemplos de operações de tratamento de dados:

- coleta;
- produção;
- recepção;
- classificação;
- utilização;
- acesso;
- reprodução;
- transmissão;
- distribuição;
- processamento;
- arquivamento;
- armazenamento;
- eliminação;
- avaliação ou controle da informação;
- modificação;
- comunicação;
- transferência;
- difusão; ou
- extração.

ESCOPO**Abrangência do tratamento:** XXXX

Considerar, por exemplo:

- *as informações sobre os tipos dos dados pessoais tratados, ressaltando quais são considerados sensíveis;*
- *categorias dos titulares de dados;*
- *o volume dos dados pessoais a serem coletados e tratados;*
- *a extensão e frequência em que os dados são tratados;*

- o período de manutenção, retenção ou armazenamento dos dados pessoais;
- o número de titulares afetados pelo tratamento; e
- a abrangência da área geográfica do tratamento.

NOTA

As informações auxiliam a determinar se o tratamento é realizado em alta escala.

CONTEXTO**Fatores internos e externos: XXXX**

Exemplos de informações que permitem demonstrar o equilíbrio entre o interesse e a necessidade do controlador em tratar os dados e os direitos dos titulares:

- natureza do relacionamento da organização com os indivíduos;
- nível ou método de controle que os indivíduos exercem sobre os dados;
- destacar se o tratamento envolve crianças, adolescentes ou outro grupo vulnerável;
- destacar se o tratamento é condizente com a expectativa dos titulares, de acordo com leis, regulamentos e comunicações da instituição;
- destaque de qualquer experiência anterior com o tipo de tratamento;
- destaque de avanços relevantes da instituição em tecnologia ou segurança que contribuem para a proteção dos dados.

NOTA

Fatores internos e externos são aqueles que podem afetar as expectativas do titular dos dados pessoais ou o impacto sobre o tratamento.

FINALIDADE**Motivo para o tratamento: XXXX**

Exemplos de objetivos a serem alcançados com o tratamento:

- cumprimento de obrigação legal ou regulatória pelo controlador;
- estudo realizado por órgão de pesquisa;
- execução de contrato ou de procedimentos preliminares relacionados a contrato do qual seja parte o titular, a pedido do titular dos dados;
- proteção da vida ou da incolumidade física do titular ou de terceiros;
- tutela da saúde;
- atender aos interesses legítimos do controlador, considerados em situações concretas (ex: apoio e promoção de atividades do controlador, proteção do exercício regular de direitos ou prestação de serviços que o beneficiem etc.), ou de terceiros; e
- garantia da prevenção à fraude e à segurança do titular.

NOTA

A finalidade do tratamento deve ser um motivo claro e específico pelo qual se deseja tratar os dados pessoais, de modo a justificar a operação e informar o titular.

NOTA

É importante:

- indicar qual(is) o(s) resultado(s) pretendido(s) para os titulares, informando o quão importantes são esses resultados;
- informar os benefícios esperados para a instituição ou para a sociedade como um todo; e
- equilibrar os interesses da instituição com os dos indivíduos com os quais tenha relacionamento.

SEÇÃO 4

PARTES INTERESSADAS CONSULTADAS

OBJETIVO DA SEÇÃO

Identificar partes internas e externas relevantes, a fim de obter opiniões legais, técnicas ou administrativas sobre os dados pessoais objeto do tratamento.

PARTE CONSULTADA	OBSERVAÇÕES A SEREM CONSIDERADAS PARA O TRATAMENTO	RISCOS DE NÃO CONFORMIDADE COM A LGPD E COM INSTRUMENTOS INTERNOS DE CONTROLE
XXXX <i>Exemplos: operador, encarregado, gestores, especialistas em segurança da informação, consultores jurídicos etc.</i>	XXXX	XXXX

NOTA

O registro de opiniões e justificativas convergentes ou divergentes pode ser considerado uma boa prática em termos de transparência, responsabilização e prestação de contas.

NOTA

Exemplos de justificativas para não registrar a consulta:

- comprometimento do segredo comercial ou industrial;
- fragilização da segurança da informação; e
- desproporcionalidade ou impraticabilidade do registro das opiniões obtidas.

SEÇÃO 5

NECESSIDADE E PROPORCIONALIDADE

OBJETIVO DA SEÇÃO

Demonstrar que o tratamento dos dados pessoais se limita ao mínimo necessário para a realização de sua finalidade, com abrangência pertinente, proporcional e não excessiva.

FUNDAMENTAÇÃO LEGAL	Fundamento: XXXX
GARANTIA DA QUALIDADE E MINIMIZAÇÃO DOS DADOS	Qualidade: XXXX <i>Exemplos de critérios de qualidade:</i> • exatidão; • clareza; • relevância; e • atualização.

	Minimização: XXXX
MEDIDAS ADOTADAS	Medidas: XXXX <i>As medidas asseguram que o operador realize o tratamento conforme a LGPD e respeite os critérios estabelecidos pelo controlador.</i>
DIREITO DO TITULAR EM RELAÇÃO AO TRATAMENTO	Implementação: XXXX <i>Descrever como estão implementadas as medidas que asseguram o direito do titular de requisitar ações e informações específicas em relação ao tratamento.</i>
INFORMAÇÕES DE PRIVACIDADE	Informações: XXXX <i>Descrever como informações de privacidade para os titulares dos dados são fornecidas.</i>
SALVAGUARDAS PARA TRANSFERÊNCIAS INTERNACIONAIS	Salvaguardas: XXXX <i>Descrever salvaguardas para transferências internacionais de dados.</i>

NOTA

No caso de fundamento no legítimo interesse do controlador, é necessário demonstrar que:

- o tratamento é indispensável;
- não há outra base legal possível de se utilizar para alcançar o mesmo propósito; e
- o processamento de fato auxilia no propósito almejado.

SEÇÃO 6

IDENTIFICAÇÃO DE AVALIAÇÃO DE RISCOS**OBJETIVO DA SEÇÃO**

Identificar qualquer tipo de risco que possa gerar impacto potencial sobre o titular dos dados pessoais (ex: comprometer a privacidade), antes de descrever medidas, salvaguardas e mecanismos de mitigação.

ID	RISCO REFERENTE AO TRATAMENTO DE DADOS PESSOAIS	P ¹	I ²	NÍVEL DE RISCO (P x I) ³
R0X R01	XXXX <i>Exemplo: acesso não autorizado</i>	X 10	X 15	X 150

NOTA

1 Probabilidade (P): chance de algo acontecer, não importando se definida, medida ou determinada objetiva ou subjetivamente, qualitativa ou quantitativamente, ou se descrita utilizando-se termos gerais ou matemáticos (ISO/IEC 31000:2009, item 2.19).

2 Impacto (I): resultado de um evento que afeta os objetivos (ISO/IEC 31000:2009, item 2.18).

3 Nível de Risco: magnitude de um risco ou combinação de riscos, expressa em termos da combinação das consequências e de suas probabilidades (ISO/IEC 31000:2009, item 2.23 e IN SGD/ME nº 1, de 2019, art. 2º, inciso XIII).

Exemplos de riscos de privacidade:

- acesso não autorizado;
- modificação não autorizada;
- perda;
- roubo;
- remoção não autorizada;
- coleção excessiva;
- informação insuficiente sobre a finalidade do tratamento;
- tratamento sem consentimento do titular dos dados pessoais, caso o tratamento não esteja previsto em legislação ou regulação pertinente;
- falha em considerar os direitos do titular dos dados pessoais (ex.: perda do direito de acesso);
- compartilhar ou distribuir dados pessoais com terceiros sem o consentimento do titular dos dados pessoais;
- retenção prolongada de dados pessoais sem necessidade;
- vinculação/associação indevida, direta ou indireta, dos dados pessoais ao titular;
- falha/erro de processamento (ex.: execução de script de banco de dados que atualiza dado pessoal com dado equivocado, ausência de validação dos dados de entrada etc.); e
- reidentificação de dados pseudoanonimizados.

NOTA

Para cada risco identificado, é importante definir:

- a probabilidade de ocorrência do evento de risco; e
- o possível impacto caso o risco ocorra, avaliando o nível potencial de risco para cada evento.

NOTA

Parâmetros escalares podem ser utilizados para representar os níveis de probabilidade e impacto. Após a multiplicação, serão obtidos os níveis de risco, que direcionarão a aplicação de medidas de segurança.

Classificação	Valor
Baixo	5
Moderado	10
Alto	15

NOTA

A Matriz Probabilidade x Impacto é um instrumento de apoio para a definição dos critérios de classificação do nível de risco. O produto da probabilidade pelo impacto de cada risco deve se enquadrar em uma região da matriz.

A região da matriz e o respectivo tipo de risco são os seguintes:

- verde – risco baixo;
- amarelo – risco moderado; e
- vermelho – risco alto.

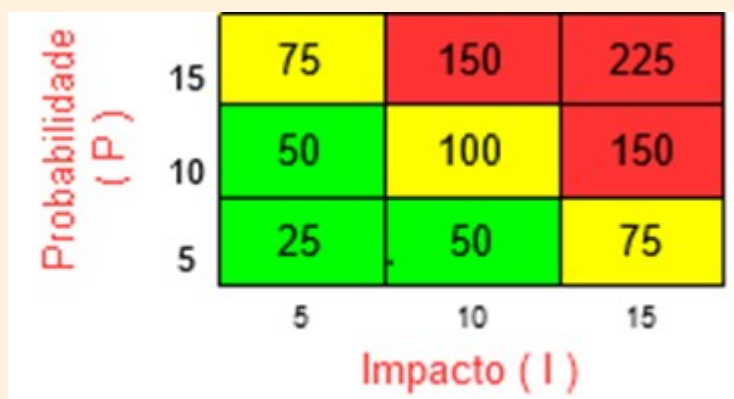


Figura 1: Matriz Probabilidade x Impacto

NOTA

O gerenciamento de riscos deve ser realizado em harmonia com a Política de Gestão de Riscos e com a Instrução Normativa Conjunta MP/CGU nº 1, de 10 de maio de 2016.

SEÇÃO 7

MEDIDAS PARA TRATAR OS RISCOS**OBJETIVO DA SEÇÃO**

Identificar as medidas adotadas pelos agentes de tratamento aptas a proteger os dados pessoais de acessos não autorizados e de situações acidentais ou ilícitas de destruição, perda, alteração, comunicação ou qualquer forma de tratamento inadequado ou ilícito.

RISCO	CONTROLE/ MEDIDA	EFEITO SOBRE O RISCO ⁴	RISCO RESIDUAL ⁵			CONTROLE/ MEDIDA APROVADO(A) ⁶
			P	I	NÍVEL (P x I)	
R0X R01	CONTROLE: Medida <i>CONTROLE 1:</i> Medida 1.1; Medida 1.2.	Efeito: <i>Exemplo: Reduzir</i>	X 5	X 10	X 50	Sim/Não

NOTA

A coluna “Controle/Medida” pode ser preenchida com controle e medida específicos adotados para tratamento do risco identificado.

As medidas para tratar os riscos podem ser:

- de segurança;
- técnicas; ou

4 Efeito resultante do tratamento do risco com a aplicação do(s) controle(s) descrito(s) na tabela. As seguintes opções podem ser selecionadas: Reduzir, Evitar, Compartilhar e Aceitar.

5 Risco residual é o risco que ainda permanece mesmo após a aplicação de controles para tratar o risco.

6 Controle/medida aprovado(a) pelo controlador dos dados pessoais. Preencher a coluna com: “Sim” ou “Não”

- administrativas.

NOTA

O [Guia do Framework de Privacidade e Segurança da Informação](#) elenca controles e medidas que representam referências fundamentais para ações de tratamento dos riscos.

Exemplos de controles/medidas para tratar riscos:

- GESTÃO DO CONTROLE DE ACESSO: Processo de concessão e revogação de acesso; Uso de MFA
- SEGURANÇA DE APLICAÇÕES: Desenvolvimento Seguro;
- PROTEÇÃO DE DADOS: Descarte seguro de dados; Uso de criptografia em mídia removível; e
- MINIMIZAÇÃO DE DADOS: Coleta somente dos dados necessários para a finalidade; Revisão periódica dos dados pessoais coletados para alinhamento com a finalidade.

NOTA

Alguns riscos podem ser aceitáveis, devido aos benefícios do processamento dos dados e as dificuldades de mitigação.

SEÇÃO 8

APROVAÇÃO**OBJETIVO DA SEÇÃO**

Formalizar a aprovação do RIPD por meio da obtenção das assinaturas: do responsável pela elaboração do RIPD; do encarregado; e das autoridades que representam o controlador e operador.

NOTA

O responsável pela elaboração do RIPD pode ser o encarregado ou pessoa designada pelo controlador com conhecimento necessário, por exemplo.

NOTA

O RIPD deve ser revisto e atualizado anualmente ou sempre que existir qualquer tipo de mudança que afete o tratamento dos dados pessoais. O [Guia de Boas Práticas LGPD](#) detalha a necessidade de revisão do RIPD.

RESPONSÁVEL PELA ELABORAÇÃO DO RIPD	ENCARREGADO
Nome: XXXX <i>Nome do responsável</i> Matrícula/SIAPE: XXXX XXXX, DD de MM de AAAA <i>Local, dia de mês de ano</i>	Nome: XXXX <i>Nome do encarregado</i> Matrícula/SIAPE: XXXX XXXX, DD de MM de AAAA <i>Local, dia de mês de ano</i>

AUTORIDADE REPRESENTANTE DO CONTROLADOR	AUTORIDADE REPRESENTANTE DO OPERADOR
Nome: XXXX <i>Nome do representante</i> Matrícula/SIAPE: XXXX XXXX, DD de MM de AAAA <i>Local, dia de mês de ano</i>	Nome: XXXX <i>Nome do representante</i> Matrícula/SIAPE: XXXX XXXX, DD de MM de AAAA <i>Local, dia de mês de ano</i>

⚠ CHECKLIST DE ENTREGA

- Todas as seções preenchidas;
- Notas e exemplos orientativos sobre o preenchimento do documento, bem como valores genéricos para os campos.

Baseado no modelo “Relatório de Impacto à Proteção de Dados Pessoais (RIPD)” do Programa de Privacidade e Segurança da Informação (PPSI)